

INDIAN SOCIETY
FOR TECHNICAL
EDUCATION
NEW DELHI



D Y PATIL
AGRICULTURE & TECHNICAL
UNIVERSITY
— TALSANDE KOLHAPUR —

Presentation on Windows Bypass Techniques: A Red Teamer's Perspective

Mr. Atharva Jagtap, Dr. Prachi Dalvi

Paper Id: ISTE-ATU-145

ISTE Global Techno 2026
The First Global Conference on Engineering, Technology, and Education
D. Y. Patil Agriculture & Technical University, Talsande

Evolution of Authentication

Windows security has transitioned from simple password-based models to complex, hardware-integrated frameworks utilizing **Windows Hello, TPM, and Virtualization-Based Security (VBS)**.

The Operational Challenge

Digital forensic analysts and Red Teams require **non-destructive access** to live systems to capture volatile artifacts (RAM, session tokens) without altering the system state or alerting defenders.

Traditional Methods Fail

Legacy "offline" attacks (e.g., SAM database modification) are destructive, break chain-of-custody, and are now rendered ineffective by **BitLocker** and **Secure Boot**.

The Critical Gap

- A significant disconnect between the claimed capabilities of older bypass tools and their actual effectiveness against modern Windows.
- Lack of a consolidated narrative explaining why legacy attacks fail.
- Insufficient focus on the implications of new attack vectors like AI and biometric exploits.

Research Objectives

- **Analyze** the architectural shift from offline SAM attacks to live memory exploitation.
- **Evaluate** the impact of hardware security (TPM, Secure Boot, VBS) on legacy tools.
- **Classify** modern attack surfaces, including biometric spoofing and DMA attacks.
- **Investigate** future threats posed by AI-driven autonomous attack agents.

LITERATURE REVIEW

Sr no.	Name of the Paper / Resource	Authors / Source	Focus	Methodologies	Key Findings
1	Privacy and Security of the Windows Registry	Amoruso (UCF Dissertation)	Security and privacy of the Windows Registry	Comprehensive dissertation, technical registry analysis, vulnerabilities, and privacy aspects	Detailed exploration of registry forensics, artifact persistence, and detection risks
2	Microsoft SAM File Readability CVE-2021-36934: What You Need to Know	Condon, Rapid7	CVE-2021-36934 Serious SAM vulnerability in the SAM database	Real-world vulnerability disclosure, proof-of-concept analysis	Allowed non-admin users access to SAM and SYSTEM files; highlights offline attack surface
3	Attacks Against Windows PXE Boot Images	Elling, NetSPI	PXE Boot images attacks & Windows boot-level vulnerabilities	Practical pentesting blog with technical walkthroughs	Demonstrates how attackers exploit Windows boot environments and PXE images
4	Bypassing Local Windows Authentication to Defeat Full Disk Encryption	Haken, Black Hat	Bypassing local Windows auth & defeating disk encryption	Conference whitepaper, threat modelling, exploit demonstration	By exploiting local (offline) authentication flaws, attackers can access encrypted systems
5	Security Analysis and Bypass User Authentication Bound to Device of Windows Hello in the Wild	Kim & Choi, Wiley	Windows Hello biometric auth bypass	Peer-reviewed research paper, real-world attack experiments	Device-bound authentication can be bypassed if biometric data is not hardware protected
6	Automating Privilege Escalation with Deep Reinforcement Learning	Kujanpää et al., arXiv	Privilege escalation via deep reinforcement learning	Simulation, machine learning for escalation	Automation reveals overlooked escalation routes in complex systems
7	Study of bypassing Microsoft Windows Security using the MITRE CALDERA Framework	Mohamed, F1000Research & Alabdulatif & Taherdoost	Using MITRE CALDERA for Windows security bypass	Peer-reviewed case study with adversarial emulation	CALDERA enables undetected bypass of Windows controls, persistence, and low-noise operations

LITERATURE REVIEW

Sr no.	Name of the Paper / Resource	Authors / Source	Focus	Methodologies	Key Findings
8	USB Artifact Analysis Using Windows Event Viewer, Registry and File System Logs	Neyaz & Shashidhar, MDPI	USB artifacts in Windows (logs, registry, filesystem)	Experimentation with forensic tools	USB drives leave identifiable artifacts, but detection can be minimized
9	Study on Security Auditing of Windows Registry Database	Tashi, IJSTE	Auditing Windows Registry Database for security	Security auditing, registry analysis	Outlines methods and limits of registry-based detection and security logging
10	Memory Forensics: comparing the correctness of memory captures from locked Windows 10 machines using different boot capture vectors	Zargari & Dyson, LAJC	Memory forensics on locked Windows 10 captured via boot	Empirical study, comparative analysis of capture vectors	Boot-vectored memory captures can expose authentication material
11	Security Accounts Manager Database	ScienceDirect, SAM overview	Technical underpinning of SAM database	Technical resource, conceptual	Details structure, interaction, and security models for local Windows accounts
12	Security Analysis and Bypass User Authentication Bound to Device of Windows Hello in the Wild	IEEE Xplore, Windows Hello auth bypass	Windows Hello & device-bound authentication vulnerabilities	Security analysis, technical review	Points to persistent weaknesses in device-bound and biometric authentication
13	AXREL: Automated Extracting Registry and Event Logs for Windows Forensics	IEEE Xplore, Registry/Event Log Extraction (AXREL)	Automated forensic artifact extraction	Describes forensic tool and methodology	Improved techniques for detecting hidden/persistent changes in Windows
14	Penetration Testing on Windows to Preserve Security	Brazilian Journals	Survey of penetration testing on Windows login bypass	Overview, compilation of tests on various bypass techniques	Documents threshold, methods, and limitations of offline/online bypass

LITERATURE REVIEW

Sr no.	Name of the Paper / Resource	Authors / Source	Focus	Methodologies	Key Findings
15	Microsoft KB5005478	Microsoft	Windows Hello security hardening	Patch notes analysis	Introduces mitigations addressing biometric authentication vulnerabilities.
16	USB Artefact Forensics	Neyaz & Shashidhar (2019)	USB forensic artefacts	Event log and registry analysis	Identifies forensic traces associated with USB device usage.
17	Boot-Capture Memory Forensics Study	Zargari & Dyson (2022)	Memory forensics accuracy	Experimental comparison	Boot method significantly affects memory artefact integrity.
18	PRMitM Password Reset Attack	Sivakorn et al. (2017)	Password reset vulnerabilities	Security protocol analysis	Demonstrates weaknesses in application-level password recovery mechanisms.
19	AI-Based Authentication Survey	Al-Ameen & Al-Khattat (2023)	AI-driven authentication	Literature review	Reviews biometric and behavioural authentication models using AI.
20	Windows Forensics Review	Chowdhury (2021)	Windows forensic investigation	Systematic review	Summarizes forensic techniques for Windows-based systems.

LITERATURE REVIEW

Sr no.	Name of the Paper / Resource	Authors / Source	Focus	Methodologies	Key Findings
21	Biometric Authentication Overview	Biggs & Williams (2019)	Biometric security models	Academic review	Explains biometric modalities and associated security risks.
22	Biometrics Security Guidance	NCSC (2024)	Secure biometric deployment	National guidance	Provides best practices and risk considerations for biometrics.
23	Windows Login Unlocker	Taiwebs	Offline credential manipulation	Software documentation	Describes live-boot techniques for resetting Windows credentials.
24	Windows Password Unlocker Professional	Vendor Documentation	Password recovery mechanisms	Tool documentation	Details methods used to remove or reset Windows passwords.
25	Resetting Windows Passwords	Passcape	Offline password modification	Technical documentation	Explains SAM database interaction and password rewriting methods.
26	Survey of Password Remover Tools	Kumar (2024)	Password reset utilities	Comparative analysis	Evaluates efficiency and limitations of password removal tools.
27	RDP NLA Bypass Advisory	Rapid7 (2019)	Remote authentication weakness	Security advisory	Identifies conditions under which Network Level Authentication can be bypassed.

From Offline SAM to Live System Exploitation

HISTORICAL CONTEXT

1993 — Present

01 The Legacy Era

Traditional attacks targeted the offline Security Accounts Manager (SAM) database. These methods were often destructive and required physical access to unencrypted drives.

- Direct Registry Manipulation
- Hash Extraction (Offline)

02 The Modern Paradigm

The modern operating systems have significantly altered the attack surface, shifting the focus away from traditional vulnerabilities toward deep integration with live system components, heavily enforced by hardware-backed security features such as the Trusted Platform Module (TPM), Secure Boot mechanisms, and Virtualization-Based Security (VBS).

HARDWARE ROOT

TPM & Secure Boot

VIRTUALIZATION

VBS / Credential Guard

Core Architectural Components



LSASS

The Local Security Authority Subsystem Service orchestrates live authentication and maintains sensitive credential data within volatile memory (RAM).



SAM Database

The Security Accounts Manager stores local user credential hashes. In modern systems, this remains encrypted and heavily guarded by the Registry Hive.



Trust Chain

Hardware anchors (TPM, UEFI Secure Boot, and VBS) form a cryptographic chain of trust that validates every stage of the boot process.

"The integration of hardware and software security has created a unified defensive posture, making component isolation the primary barrier for any bypass attempt."

Hardware Anchored Defense

How modern Windows architecture has rendered traditional offline manipulation obsolete through cryptographic enforcement.

Cryptographic Isolation

BitLocker Full Disk Encryption (FDE) renders the SAM and Registry files useless without the correct decryption key, which is never stored in plaintext on the disk.

Boot Integrity

Secure Boot ensures only signed, trusted Microsoft code loads during startup, preventing the injection of rogue bootloaders or kernels designed to bypass login.

01 BITLOCKER ENCRYPTION

02 SECURE BOOT INTEGRITY

03 TPM KEY SEALING

TPM ENFORCEMENT MECHANISM

The Trusted Platform Module (TPM) seals the BitLocker key.

If the system detects any unauthorized change to the boot files or BIOS configuration (Platform Configuration Registers), the TPM refuses to release the key, locking the entire drive.

Taxonomy of Bypass Techniques

OFFLINE ATTACKS

Media-Dependent Entry

Requires physical access and the ability to boot from external media (USB/PXE) to modify system files directly.

- ✗ Direct SAM database modification (e.g., clearing passwords)
- ✗ Replacement of system binaries (Utilman/Sethc)

ONLINE / LIVE ATTACKS

Runtime Exploitation

Focuses on exploiting active OS processes or hardware vulnerabilities while the system is operational.

- ✓ Memory injection targeting the LSASS process
- ✓ Protocol-level exploits and session hijacking

FORENSIC IMPACT

Highly destructive; leaves significant footprints and often corrupts user profile integrity.

STRATEGIC ADVANTAGE

Favored by Red Teams as they preserve RAM state and maintain access to critical forensic artifacts.

Advanced Exploits

The New Frontiers of Authentication Bypass



Hardware Attacks (DMA)

Direct Memory Access exploits target live RAM via high-speed ports (Thunderbolt/Firewire), bypassing OS-level memory protections entirely.



Rogue USB Devices

Tools like the LAN Turtle or PoisonTap emulate network adapters to capture NTLMv2 hashes or hijack sessions during the login phase.



Windows Hello Vulnerabilities

Biometric spoofing and migration attacks target the convenience layer, exploiting the transition between biometric auth and cryptographic keys.



Deprecated Vectors

chntpw / SAM Editing

NEUTRALIZED

Utilman.exe Hijacking

NEUTRALIZED

PE Unlockers

FAILED (22H2+)

Integrated hardware security models (TPM/BitLocker) have rendered traditional, destructive offline methods largely ineffective on post-2022 Windows versions.

Active Defense Mechanisms



VBS & Credential Guard

Shields LSASS memory from kernel-level access using virtualization-based security, preventing memory-scraping tools.



Hardware-Enforced Isolation

Mandatory TPM 2.0 and Secure Boot ensure the operating system environment is untampered before authentication occurs.

CONCLUSION

The focus has decisively shifted from disk-based attacks to live-state exploitation.

FUTURE SCOPE

Intact Bypass

Research is moving toward maintaining the 'Intact' state of the OS, avoiding detection by EDR and preserving system stability during bypass.

Offensive AI

Automated exploit chaining powered by AI to identify transient weaknesses in live system memory and hardware interfaces in real-time.

Protocol Vectors

Weaknesses in authentication protocols (Kerberos/NTLM) remain viable vectors for circumventing even the most hardened OS configurations.

"The challenge of the next decade is not breaking the lock, but convincing the system that you are the keyholder through protocol and memory manipulation."

Kim, Y., & Choi, J. (n.d.). *Security analysis and bypass user authentication bound to device of Windows Hello in the wild*. Wiley
Peer-reviewed research paper analyzing real-world Windows Hello biometric authentication bypass techniques.

Kujanpää, K., et al. (n.d.). *Automating privilege escalation with deep reinforcement learning*. arXiv.
Preprint exploring automated privilege escalation using deep reinforcement learning in simulated environments.

Neyaz, A., & Shashidhar, V. (n.d.). *USB artifact analysis using Windows Event Viewer, registry and file system logs*. MDPI.
Experimental forensic study identifying USB usage artefacts in Windows systems.

Security Accounts Manager database. (n.d.). ScienceDirect.
Technical reference describing the architecture, operation, and security model of the Windows SAM database.

Kim, Y., & Choi, J. (n.d.). *Security analysis and bypass user authentication bound to device of Windows Hello in the wild*. IEEE Xplore.
Security analysis highlighting weaknesses in device-bound and biometric authentication mechanisms in Windows Hello.

Chowdhury, R. (2021). *Windows forensics review*.
Systematic review summarizing forensic methodologies applicable to Windows operating systems.

Windows Login Unlocker. (n.d.). Taiwebs.
Software documentation describing live-boot based techniques for offline Windows credential manipulation.



D Y PATIL
AGRICULTURE & TECHNICAL
UNIVERSITY
— TALSANDE KOLHAPUR —

THANK YOU